

Cerebro Field Notes

How Security Operations Really Runs It

Security Operations Engineering

Internal Brownbag

Reality Check: Life on SecOps On-Call

- ▶ Findings live in five tools, none agree; analysts lose the first hour reconciling truth.
- ▶ Evidence requests arrive during active incidents, forcing screenshot theater.
- ▶ Leadership needs answers now: "Are we compromised?" and "Can auditors sign off?"

What Cerebro Promises

- ▶ **One nervous system:** every interface hits the same append-only store, so "source of truth" is literal.
- ▶ **Answers on demand:** graph + SQL over live data replaces stale exports and ad-hoc spreadsheets.
- ▶ **Guardrailed automation:** agents accelerate response without bypassing approvals or audit trails.

Before vs. With Cerebro: 08:00 Pager

Old World

- ▶ Refresh five consoles, Slack the IAM team, hope CSV exports finish.
- ▶ Manual notes in docs, no audit trail for leadership checks.
- ▶ Every exec update is guesswork stitched from stale exports.

With Cerebro

- ▶ Spin up scoped agent session; agents, CLI, UI share identical findings.
- ▶ Every question, tool call, and decision lands in `agent_audit_events`.
- ▶ Query engine + timelines feed exec-ready answers in minutes.

How We Kick Off the Day

- ▶ **Problem:** Analysts waste time validating whether alerts are real.
- ▶ **Move:** On-call runs `make dev` locally, launches agent session locked to the hot org.
- ▶ **Outcome:** Within three minutes, they have an annotated list of high-risk findings with mapped controls.

Analyst POV

- ▶ "I ask: *What changed overnight?* The agent answers with fresh diffs and links to evidence bundles."
- ▶ "Follow-ups like *Who owns this account?* already have IAM stitching applied—no back-and-forth."
- ▶ "When leadership pings, I paste the audit trail instead of rewriting Slack updates."

Why Unified Collection Matters

- ▶ Without it, asset inventories drift and responders chase ghosts.
- ▶ Cerebro's collector sweeps resources, principals, configs, and IAM edges in one motion.
- ▶ Identity stitching turns SaaS fragments into human-readable owners, so escalations hit the right inbox.

Story: New Acquisition, Zero Visibility

- ▶ **Trigger:** M&A team drops a GitHub org on Friday night.
- ▶ **Cerebro Move:** Collector job runs in background; account inventories populate, configs hashed, alerts normalized.
- ▶ **Outcome:** Monday 09:00 briefing includes exposure counts, owners, and evidence bundles—no heroic spreadsheeting.

The Query Engine in Human Terms

- ▶ Analysts phrase questions like *"Show MFA gaps for prod admins"*; the engine answers in seconds.
- ▶ Dashboards, agent responses, and compliance reports all reuse the same SQL call—consistency by design.
- ▶ Evidence generation pulls straight from those queries, so auditors get signed artifacts instead of screenshots.

Scenario: Leaked Token Midnight Wednesday

- ▶ Agent session seeded with incident ID auto-loads prior context and open findings.
- ▶ Responder asks *"Rebuild the compromise timeline"*; timeline tool reconstructs actions with timestamps and actors.
- ▶ Leadership call gets facts: blast radius, affected principals, mitigations underway.

Why Agents Stay Trustworthy

- ▶ ToolExecutor enforces dry-run and CEL policies; destructive moves require explicit approval.
- ▶ Every tool invocation logs who asked, what context was used, and how long it took—perfect for post-incident reviews.
- ▶ If an agent hallucinates, analysts override once and the audit record captures the correction for follow-up.

Evidence Without Panic

- ▶ WORM evidence bundles package SQL, configs, and screenshots with signatures.
- ▶ Chain-of-custody lives inside the bundle; no more emailing ZIPs around.
- ▶ Same artifacts satisfy incident retros, regulator questions, and customer assurances.

Why Finance and Audit Care

- ▶ Control tests run continuously; failed tests route straight into the remediation queue SecOps already works.
- ▶ Policy attestations, device posture, and technical findings share one dashboard—no duplicate status meetings.
- ▶ When auditors ask "Prove MFA is enforced," we hand over the signed evidence bundle generated during the incident.

One Platform, Two Conversations

- ▶ SOC leaders talk in risk narratives; finance speaks SOC 2 controls—Cerebro outputs both from the same data.
- ▶ Time-to-audit-packet dropped from days to hours once evidence bundling shipped.
- ▶ We now justify budget by pointing to avoided fines and measurable response time cuts.

Investments That Unlock More Why

- ▶ Auto-context loading so agents stop asking for org basics—saves analysts from repeating themselves.
- ▶ Proactive monitors that nudge teams before humans spot drift—turn firefighting into prevention.
- ▶ Feedback capture so corrections improve future runs—keeps trust high as automation expands.

Contact: soc-engineering@writer.com